

Relazione Tecnica - SQL Injection (BW II, Giorno 1)

Il presente elaborato riporta le attività svolte durante l'esercitazione di SQL Injection su DVWA (Damn Vulnerable Web Application), eseguita in ambiente di laboratorio, con l'obiettivo di individuare la vulnerabilità, estrarre le credenziali dell'utente target e recuperarne la password in chiaro mediante John the Ripper.

1. Configurazione dell'ambiente

Parametro	Valore
DVWA	LOW
Kali Linux	192.168.13.100
Metasploitable 2	192.168.13.150
URL	http://192.168.13.150/dvwa/

Le due macchine virtuali sono state configurate sulla stessa rete ed è stata verificata la connettività tramite ping.

The image shows two overlapping windows from a virtual machine environment. The top window is a Kali Linux terminal with the following content:

```
kali@kali:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.13.100/24 brd 192.168.13.255 scope global noprefixroute eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe06:4409/64 scope link
        valid_lft forever preferred_lft forever

kali@kali:~$ ping -c 4 192.168.13.150
PING 192.168.13.150 (192.168.13.150) 56(84) bytes of data:
 64 bytes from 192.168.13.150: icmp_seq=1 ttl=64 time=0.677 ms
 64 bytes from 192.168.13.150: icmp_seq=2 ttl=64 time=0.400 ms
 64 bytes from 192.168.13.150: icmp_seq=3 ttl=64 time=0.402 ms
 64 bytes from 192.168.13.150: icmp_seq=4 ttl=64 time=0.400 ms

--- 192.168.13.150 ping statistics ---
 4 packets transmitted, 4 received, 0% packet loss, time 3067ms
 rtt min/avg/max/mdev = 0.400/0.471/0.677/0.118 ms

kali@kali:~$
```

The bottom window is titled 'Metasploitable [in esecuzione] - Oracle VM VirtualBox' and shows the following content:

```
# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.13.150
netmask 255.255.255.0
network 192.168.13.0
broadcast 192.168.13.255
gateway 192.168.13.1

msfadmin@metasploitable:~$ sudo /etc/init.d/networking restart
* Restarting networking interfaces: .
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:06:44:09 brd ff:ff:ff:ff:ff:ff
    inet 192.168.13.150/24 brd 192.168.13.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe06:4409/64 scope link
        valid_lft forever preferred_lft forever

msfadmin@metasploitable:~$
```

Figura 1 - Configurazione IP e verifica della connettività.

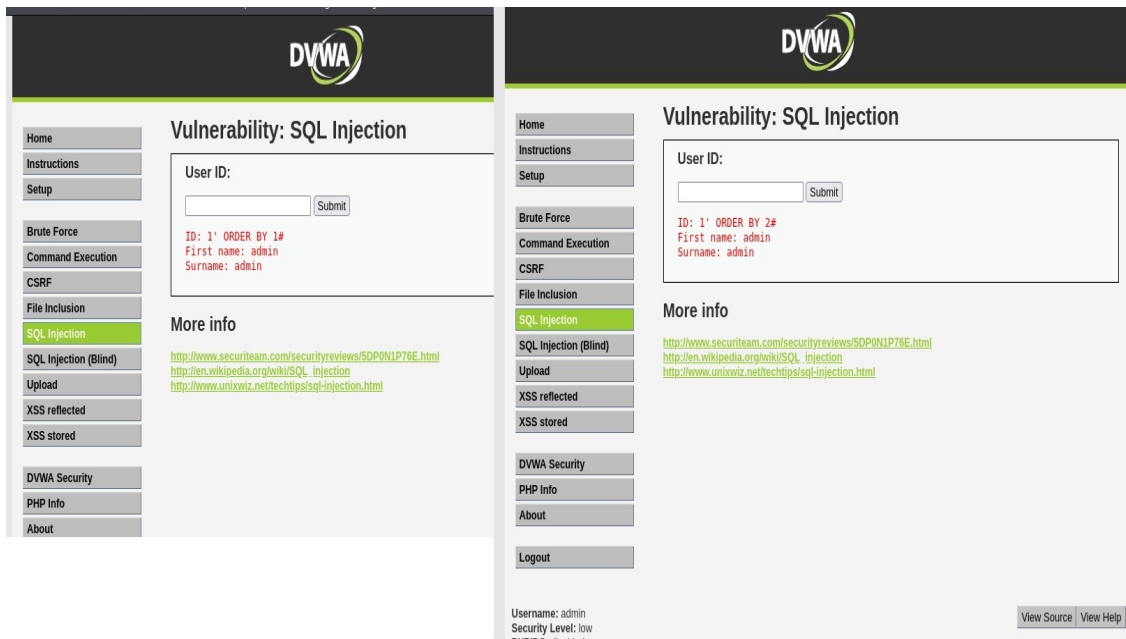


Figura 2 - Enumerazione delle colonne mediante ORDER BY.

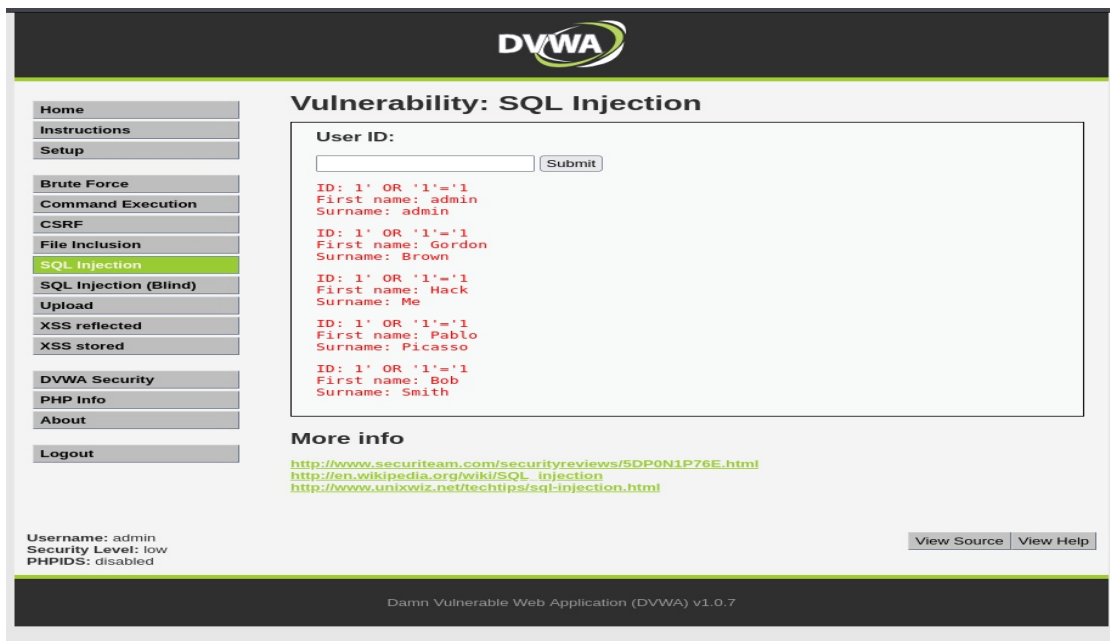


Figura 3 - Verifica della vulnerabilità SQL Injection.

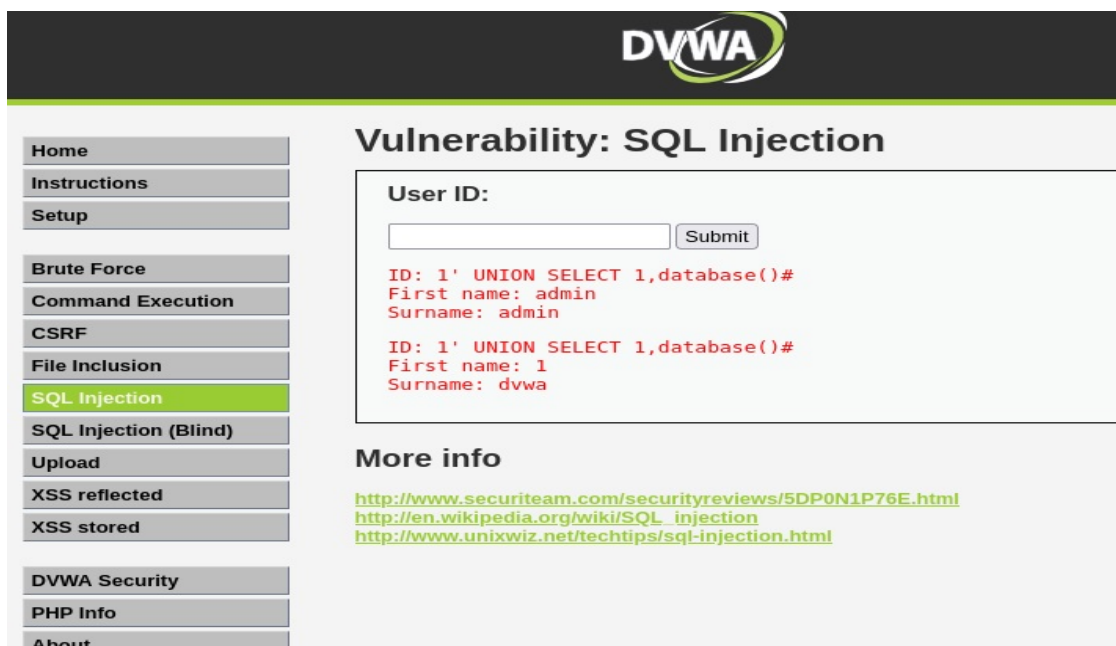


Figura 4 – Individuazione del database utilizzato (dvwa).



Figura 5 – Enumerazione delle tabelle del database.

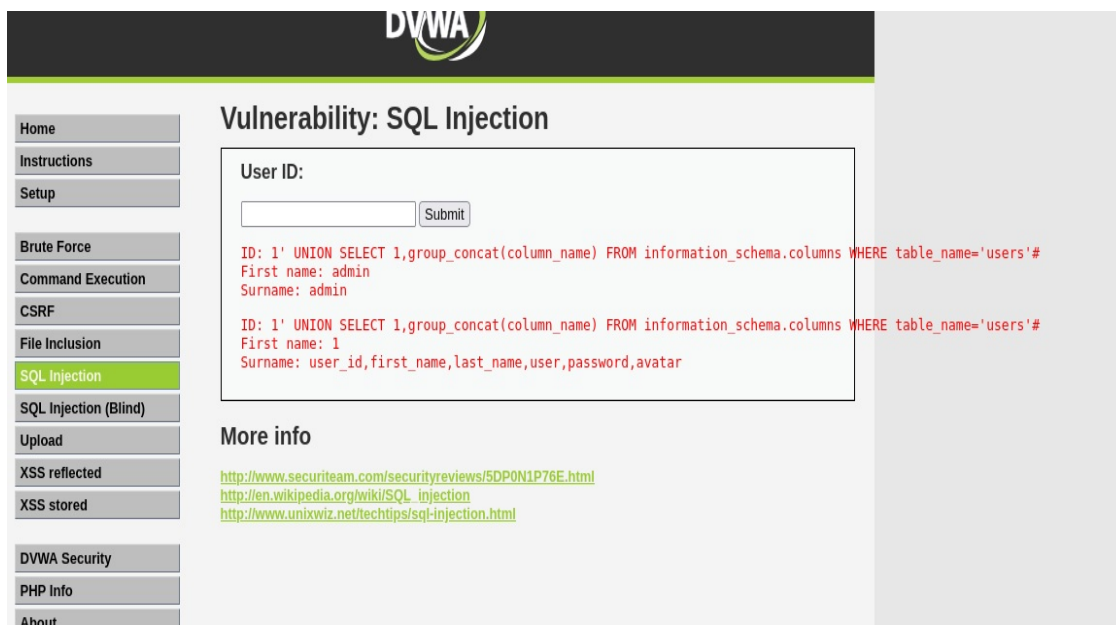


Figura 6 - Individuazione delle colonne della tabella users.

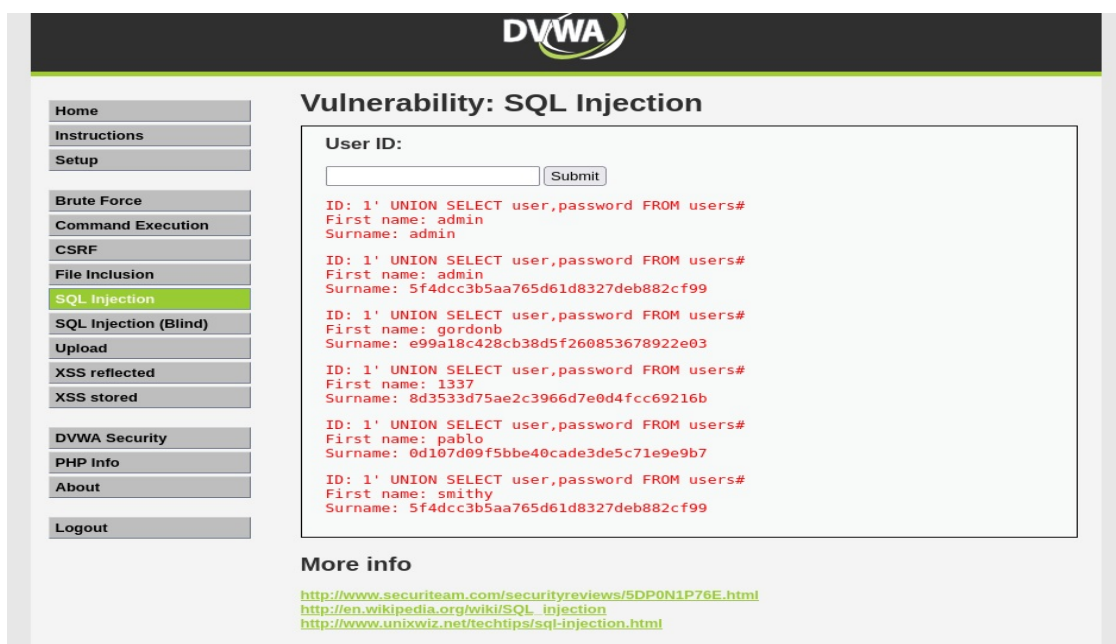


Figura 7 - Estrazione degli username e degli hash MD5.

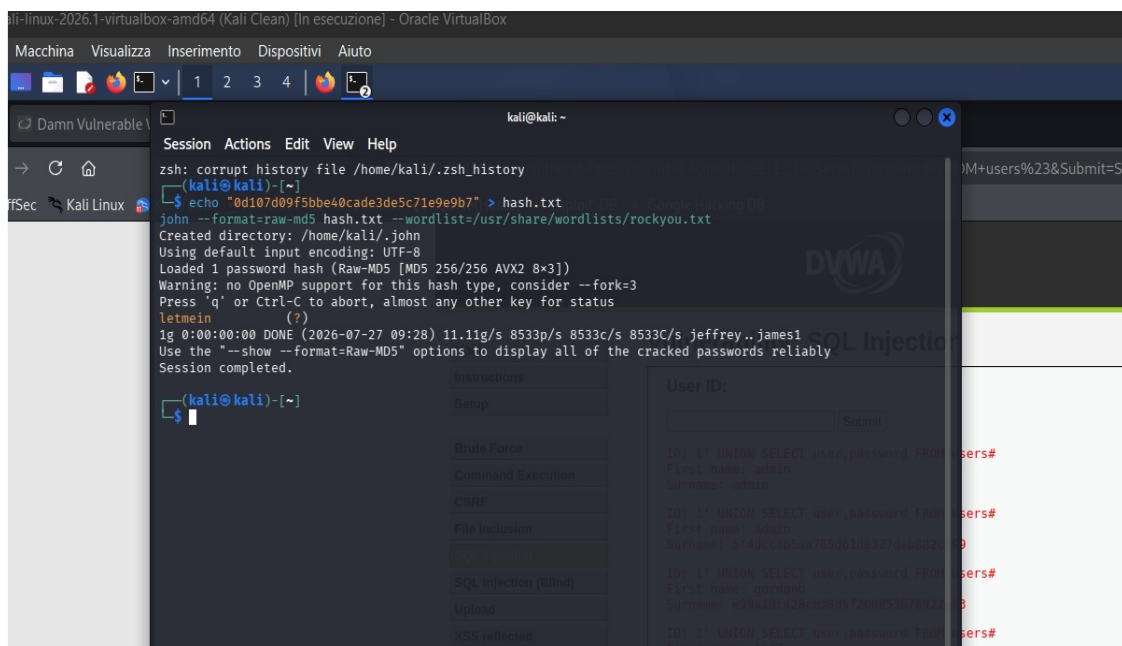


Figura 8 - Cracking dell'hash con John the Ripper.

Conclusioni

L'esercitazione è stata completata con successo. Sono state eseguite la configurazione dell'ambiente, la verifica della vulnerabilità, l'enumerazione di database, tabelle e colonne, l'estrazione degli hash degli utenti e il recupero della password dell'utente target mediante John the Ripper. La relazione copre tutti i punti richiesti dalla traccia (bonus escluso).